

Manual 21 — OT / ICS Security Controlled Implementation

Controlled English master — development

****Series order:**** 21

****Primary public baseline:**** NIST SP 800-82 Rev. 3

****Reference boundaries:**** ISA/IEC 62443 series; CISA ICS/OT advisories and mitigations

****Control boundary:**** This manual provides original implementation guidance. It does not reproduce protected standards text, establish certification, supersede safety engineering, or convert advisories into mandatory requirements.

1. Purpose, scope, and source boundaries

Define the OT/ICS environments, facilities, processes, systems, networks, applications, field devices, support services, and interfaces covered by the security program. Record authoritative source versions and distinguish public control guidance, copyrighted standards-family references, vendor documentation, and time-sensitive advisories. Evidence includes the approved scope, source register, exclusions, facility/system map, and source-change watch.

2. OT mission, safety, and process context

Security decisions must preserve safe and reliable operation of the physical process. Document critical process functions, safety dependencies, environmental constraints, availability requirements, maximum tolerable disruption, and conditions in which cybersecurity changes require engineering or safety review. Evidence includes process criticality records, hazard/safety interfaces, operational constraints, and approved security-versus-operability decisions.

3. Governance, roles, and accountability

Establish accountable ownership across executives, plant/facility leadership, control engineering, operations, safety, cybersecurity, IT, physical security, vendors, and incident leadership. Define decision rights for risk acceptance, remote access, changes, outages, emergency actions, and supplier access. Evidence includes charter, RACI, escalation paths, deputies, meeting records, and decisions.

4. Zones, conduits, and architecture segmentation

Model trusted zones, security levels or equivalent risk groupings, conduits, boundary devices, control centers, safety systems, supervisory systems, engineering workstations, field networks, enterprise interfaces, vendor paths, and external dependencies. Use segmentation to limit unnecessary communication while preserving required process flows. Evidence includes current diagrams, approved flow matrices, boundary rules, exceptions, and validation results.

5. OT asset inventory and ownership

Maintain authoritative inventories for controllers, PLCs, DCS components, HMIs, historians, engineering workstations, safety-system components, gateways, network devices, servers, virtual assets, wireless devices, sensors, actuators, applications, firmware, and supporting infrastructure. Record owner, location, function, criticality, version, network identity, support status, and lifecycle state. Reconcile passive discovery, engineering records, maintenance data, and approved inventories.

6. System and component classification

Classify systems and components according to process criticality, safety consequence, operational dependency, exposure, recoverability, and cybersecurity impact. Avoid using a single business-impact score where physical consequence or loss of control requires separate treatment. Evidence includes classification criteria, component/system ratings, rationale, inherited dependencies, and reassessment triggers.

7. OT cybersecurity risk assessment

Assess credible threat scenarios using architecture, exposure, known weaknesses, adversary capability, process consequence, safety impact, environmental impact, recovery difficulty, and existing safeguards. Include cyber-physical pathways and dependencies on IT, cloud, remote vendors, telecommunications, and shared services. Evidence includes scenario-based risk records, assumptions, safeguards, residual risk, owners, and treatment decisions.

8. Secure configuration and hardening

Define approved configuration baselines appropriate to each OT technology and process constraint. Disable unnecessary services and interfaces where technically safe, protect administrative functions, manage default credentials, control removable functionality, secure time sources, and document deviations required for operations. Evidence includes baselines, configuration exports, hardening checks, deviations, validation, and remediation records.

9. Identity, authentication, and access control

Apply least privilege and individual accountability where technically feasible while recognizing legacy-device limitations and emergency operational needs. Separate operator, engineer, administrator, service, vendor, and application privileges. Protect privileged credentials, govern shared or local accounts, and document compensating safeguards when strong authentication cannot be implemented directly on a device. Evidence includes account inventories, role mappings, approvals, reviews, and exception records.

10. Remote access and privileged maintenance

Permit remote connectivity only through approved, monitored, time-bounded pathways aligned to operational need. Require explicit authorization, secure intermediary access, strong authentication where supported, session logging or equivalent evidence, and rapid revocation. Emergency access must be separately controlled and reviewed afterward. Evidence includes remote-access architecture, access records, session evidence, approvals, vendor identities, and termination tests.

11. Network segmentation and boundary protection

Control traffic between enterprise IT, OT supervisory networks, control zones, safety-related environments, wireless segments, vendor networks, and external services. Use allow-listed communications where feasible, restrict administrative protocols, protect management interfaces, and verify rules against documented process flows. Evidence includes firewall/ACL configurations, flow baselines, rule reviews, segmentation tests, and exception tracking.

12. Industrial protocols and communications security

Inventory industrial and supporting protocols, their trust assumptions, authentication/encryption capabilities, routing exposure, and operational dependencies. Apply secure variants, gateways, protocol filtering, integrity checks, or compensating segmentation where native controls are limited. Do not enable protocol changes without engineering validation. Evidence includes protocol maps, approved commands/flows, protection settings, and test results.

13. Defensive architecture and layered safeguards

Design defense in depth across physical access, network boundaries, hosts, applications, identities, engineering workflows, monitoring, backups, recovery, and operational procedures. Avoid relying on a single firewall, endpoint product, or air-gap assumption. Evidence includes layered-control architecture, dependency analysis, failure-mode review, compensating safeguards, and validation exercises.

14. Monitoring, logging, and anomaly detection

Collect security and operational telemetry proportionate to risk without destabilizing control processes. Prioritize boundary devices, authentication systems, engineering workstations, servers, remote-access systems, critical configuration changes, and passive OT network monitoring. Define time synchronization, retention, alert triage, baseline behavior, and escalation. Evidence includes coverage maps, log-source health, detections, investigations, tuning records, and retention settings.

15. Vulnerability and exposure management

Maintain a risk-based process for identifying vulnerabilities, insecure configurations, exposed services, unsupported components, and relevant advisories. Evaluate exploitability together with process consequence, exposure, vendor guidance, compensating safeguards, and maintenance windows. Do not equate a raw severity score with OT risk. Evidence includes findings, advisory correlation, engineering assessment, treatment decisions, mitigations, retests, and risk acceptances.

16. Patch and update management

Evaluate firmware, operating-system, application, and security updates through vendor support information, engineering compatibility, test environments where feasible, rollback planning, maintenance windows, and process/safety impact. Prioritize risk-reducing actions while avoiding untested changes to critical production systems. Evidence includes patch inventories, applicability decisions, test results, approvals, deployment records, rollback plans, and deferred-risk treatment.

17. Configuration and change control

Route hardware, software, logic, network, firmware, account, rule, and architecture changes through controlled assessment and approval. Define emergency-change paths and post-change review. Verify backups and recovery points before material changes, preserve prior configurations, and monitor unauthorized drift. Evidence includes change tickets, engineering review, test records, approvals, before/after configurations, and validation results.

18. Backups, restoration, and recovery engineering

Protect recoverable copies of control logic, configurations, recipes, historian settings, server images, critical documentation, licenses, keys, and other required restoration material. Maintain offline or otherwise protected copies where appropriate and test restoration under realistic conditions. Evidence includes backup inventories, protection settings, restore tests, recovery dependencies, recovery time observations, and remediation.

19. OT incident response

Maintain OT-specific detection, triage, containment, eradication, recovery, evidence preservation, communications, and escalation procedures integrated with safety and operations. Cyber containment that could change the physical process requires authorized operational judgment. Define when isolation, shutdown, manual operation, vendor engagement, or law-enforcement/regulatory escalation may be considered. Evidence includes plans, contact trees, incidents, exercises, decisions, timelines, and lessons learned.

20. Continuity, degraded modes, and manual operations

Define how critical processes can continue safely during cyber disruption, loss of enterprise connectivity, loss of supervisory functions, ransomware events, unavailable vendors, or compromised engineering services. Document degraded modes and manual procedures only where operationally valid and trained. Evidence includes continuity plans, dependency maps, manual-operation procedures, exercise results, recovery priorities, and corrective actions.

21. Supplier and third-party OT security

Inventory vendors, integrators, maintenance providers, OEMs, managed services, cloud services, telecom dependencies, and software/component suppliers that can affect OT. Define security requirements for remote access, credentials, updates, incident notification, support lifecycle, subcontractors, evidence, and termination. Evidence includes contracts, assessments, access records, support notices, component provenance, and remediation tracking.

22. Secure engineering and system lifecycle

Integrate cybersecurity requirements from design and procurement through commissioning, operation, modification, maintenance, and decommissioning. Define secure design reviews, acceptance criteria, architecture documentation, factory/site acceptance security checks where appropriate, lifecycle support expectations, and secure retirement. Evidence includes requirements, design reviews, acceptance records, lifecycle plans, and decommissioning evidence.

23. Physical and environmental protection

Coordinate cyber controls with facility access, cabinets, control rooms, field locations, ports, removable interfaces, power, cooling, environmental controls, and tamper risks. Apply protections based on consequence and practical operating conditions. Evidence includes access-control records, physical inspections, environmental monitoring, cabinet/port controls, visitor/vendor records, and corrective actions.

24. Removable media and portable devices

Control laptops, portable engineering stations, removable storage, diagnostic devices, and vendor media before connection to OT. Define authorization, malware scanning or controlled transfer processes, device ownership, approved tools, data handling, and post-use review. Where scanning cannot safely occur on the target system, use controlled intermediary processes. Evidence includes device/media registers, approvals, scan/transfer records, and exceptions.

25. Wireless and radio-enabled OT

Inventory wireless technologies and radio-enabled maintenance or operational interfaces, including Wi-Fi, cellular, Bluetooth, proprietary radio, and industrial wireless. Document coverage, authentication, encryption, key management, interference/resilience concerns, rogue-device monitoring, and fallback operations. Evidence includes wireless inventories, configurations, surveys, key-rotation records, monitoring, and risk decisions.

26. Safety-system coordination and independence

Treat safety instrumented systems and other protection functions according to their engineering and safety requirements. Assess cybersecurity dependencies, communications paths, maintenance access, common-mode failures, and independence needs without claiming cybersecurity controls can replace functional-safety engineering. Evidence includes interface diagrams, independence reviews, access rules, testing coordination, and approved exceptions.

27. Security testing and validation

Plan testing so it does not create unacceptable process risk. Prefer representative test environments, passive techniques, vendor-supported methods, controlled windows, and rollback capability for production systems. Define rules of engagement for vulnerability assessment, penetration testing, segmentation validation, recovery testing, and configuration verification. Evidence includes test plans, safety/operations approvals, results, findings, remediation, and retests.

28. Metrics, KRIs, and evidence architecture

Measure meaningful OT security outcomes such as inventory coverage, unsupported assets, exposed pathways, remote-access use, monitoring coverage, overdue risk treatments, patch/mitigation status, restoration success, incident recurrence, and exception aging. For each safeguard record owner, procedure, trigger/frequency, evidence object, location, test method, findings, remediation, and reassessment trigger. Metrics support but do not replace risk judgment.

29. Cross-framework mapping governance

Map NIST SP 800-82 concepts, ISA/IEC 62443 references, organizational controls, enterprise frameworks, and regulatory obligations only as traceable aids. Do not assert one-to-one equivalence or certification inheritance. Record source/version, mapping rationale, gaps, ambiguity, reviewer/date where substantive mapping judgment is required, and change impacts.

30. Training and competency

Provide role-specific competency for operators, engineers, administrators, incident responders, security analysts, safety personnel, procurement, and vendors. Training should cover approved access, change processes, removable media, remote support, anomaly reporting, incident actions, and cyber-physical consequence. Evidence includes role curricula, completion, exercises, observed performance, and corrective coaching.

31. Exceptions and risk acceptance

Document exceptions with affected asset/process, requirement or safeguard, technical/operational rationale, consequence, compensating controls, accountable approver, expiration, remediation target, and reassessment triggers. High-consequence exceptions require proportionate scrutiny and must not become permanent through administrative neglect. Evidence includes exception register, reviews, residual-risk decisions, and closure records.

32. Source change, localization, artifact QA, and release controls

Maintain change watch for NIST publications, ISA/IEC 62443 editions, CISA advisory practices, relevant vendor support notices, and other adopted source material. Freeze the exact controlled English source before es-419 and pt-BR localization. Mark project translations as unofficial. Require trilingual parity, reproducible six-binary DOCX/PDF generation, deterministic rendering and accessibility QA, SHA-256 provenance, workflow security, durable exact-byte staging, predecessor publication, catalog/release-registry reconciliation, and reopening of affected gates after material source or content change.

Controlled release boundary

This development master is implementation guidance, not legal advice, product certification, safety certification, or an ISA/IEC 62443 certification claim. CISA advisories and vendor notices are time-sensitive operational inputs rather than permanent normative requirements. Under the repository's canonical rule, a clean candidate with all applicable objective gates green and its predecessor published proceeds under standing release authorization unless a specific documented non-deterministic specialist issue genuinely requires separate judgment.